



THE DEVIL IS IN THE DATA

Why AI Exposes Your Weakest Controls

DATA SECURITY • PRIVACY RISKS • COMPLIANCE CHALLENGES

“AI doesn’t introduce new data risks — it amplifies the ones you’ve been tolerating.”

Ron Woerner, CISM

President, Chief Curmudgeon, Cyber-AAA, LLC,
<https://www.linkedin.com/in/ronwoerner/>



>whoami

Ron Woerner

- Hacker
- Cybersecurity Consultant / Trusted Advisor
- Adjunct Professor, Bellevue University
- 25+ years experience in IT / Security
- Blogger, writer, and podcaster

LinkedIn:

<https://www.linkedin.com/in/ronwoerner/>



TEDx Omaha, 2019
[Hackers Wanted](#)

Websites & Social Media:

<https://linktr.ee/cyberron>

Warning!

- These are my thoughts based on my studies and experiences and NOT necessarily those of my employers or anyone else
- Ethical uses only
- Use at your own risk / Normal caveats apply
- This talk goes FAST!
- There is homework!



A person wearing a dark hooded garment is shown in profile, looking upwards. The background is solid black.

WHY
are we here?

Data for Thought

*“Garbage in,
compliance
violation out.”*

*“AI doesn’t
forget—
especially your
mistakes.”*

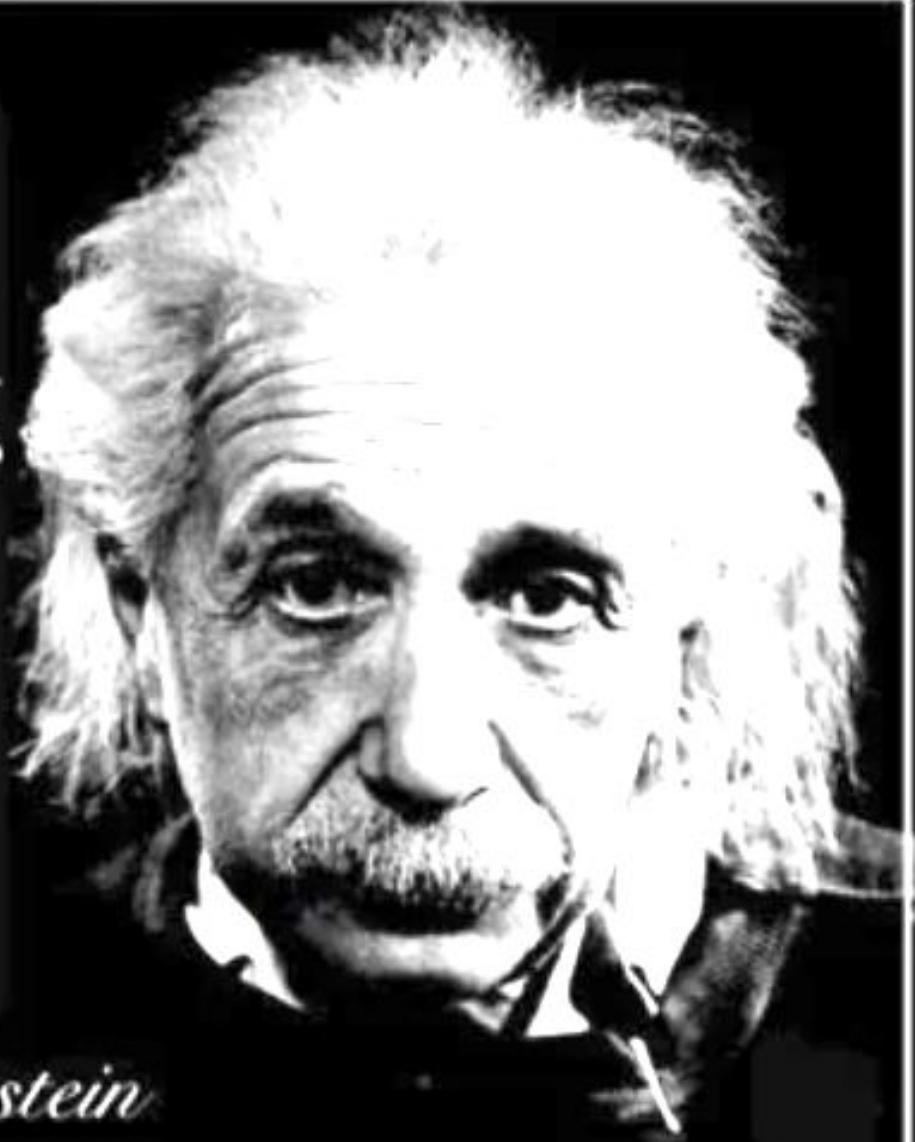
*“Data without
governance is just
liability at scale.”*

*“Access is the
new attack
surface.”*

*“If everyone owns
the data, no one
protects it.”*

Insanity:
doing the same thing
over and over again
and expecting
different results.

- Albert Einstein



Audience Takeaways*

Data visibility is non-negotiable

- You need classification, lineage, and ownership—not just storage.

AI is a force multiplier (good and bad)

- Weak controls → exponential exposure
- Strong controls → competitive advantage

Traditional security ≠ data protection

- Perimeter and identity controls don't solve data misuse.

Governance must be operationalized

- Policies without enforcement = zero control

Start small but structured

- Focus on critical datasets, not “boil the ocean”





It's 10PM.
Do you know where your data is?

THE ILLUSION OF CONTROL

Most organizations don't know where
their sensitive data actually lives.

Your AI copilot is trained on a shared drive
with 10 years of unclassified data...
what could go wrong?

Data Chaos Meets AI

*If your data is messy,
your AI will be messy — and risky.*

Themes:

Data sprawl (cloud, SaaS, shadow IT & AI)

Lack of classification and ownership

Over-permissioning (“Everything has access to everything”)

AI ingesting uncontrolled datasets

Examples:

Sensitive data in shared folders & training datasets

Prompt leakage / model memorization

Regulatory exposure (GDPR, HIPAA, etc.)

ATLAS Matrix

The ATLAS Matrix below shows the progression of tactics used in attacks as columns from left to right, with ML techniques belonging to each tactic below. [&] indicates an adaption from ATT&CK. Click on the blue links to learn more about each item, or search and view ATLAS tactics and techniques using the links at the top navigation bar. View the ATLAS matrix highlighted alongside ATT&CK Enterprise techniques on the [ATLAS Navigator](#).



Reconnaissance ^{&}	Resource Development ^{&}	Initial Access ^{&}	AI Model Access	Execution ^{&}	Persistence ^{&}	Privilege Escalation ^{&}	Defense Evasion ^{&}	Credential Access ^{&}	Discovery ^{&}	Lateral Movement ^{&}	Collection ^{&}	AI Attack Staging	Command and Control ^{&}	Exfiltration ^{&}	Impact ^{&}
8 techniques	13 techniques	7 techniques	4 techniques	6 techniques	9 techniques	4 techniques	15 techniques	6 techniques	9 techniques	2 techniques	4 techniques	6 techniques	3 techniques	6 techniques	9 techniques
Active Scanning ^{&}	Acquire Infrastructure	AI Supply Chain Compromise	AI Model Inference API Access	AI Agent Clickbait	AI Agent Context Poisoning	AI Agent Tool Invocation	AI Supply Chain Reputation Inflation	AI Agent Tool Credential Harvesting	Cloud Service Discovery ^{&}	Phishing ^{&}	AI Artifact Collection	Craft Adversarial Data	AI Agent	Exfiltration via AI Agent Tool Invocation	Cost Harvesting
Gather RAG-Indexed Targets	Acquire Public AI Artifacts	Drive-by Compromise ^{&}	AI-Enabled Product or Service	AI Agent Tool Invocation	AI Agent Tool Data Poisoning	AI Agent Tool Data Poisoning	AI Supply Chain Rug Pull	Credentials from AI Agent Configuration	Discover AI Agent Configuration	Use Alternate Authentication Material ^{&}	Data from AI Services	Create Proxy AI Model	AI Service API	Exfiltration via AI Inference API	Data Destruction via AI Agent Tool Invocation
Gather Victim Identity Information ^{&}	Develop Capabilities ^{&}	Evade AI Model	Full AI Model Access	Command and Scripting Interpreter ^{&}	AI Agent Tool Poisoning	LLM Jailbreak	Corrupt AI Model	Exploitation for Credential Access ^{&}	Discover AI Artifacts		Data from Information Repositories ^{&}	Generate Deepfakes	Reverse Shell	Exfiltration via Cyber Means	Denial of AI Service
Search Application Repositories	Establish Accounts ^{&}	Exploit Public-Facing Application ^{&}	Physical Environment Access	Deploy AI Agent	LLM Prompt Self-Replication	Valid Accounts ^{&}	Delay Execution of LLM Instructions	OS Credential Dumping ^{&}	Discover AI Model Family		Data from Local System ^{&}	Generate Malicious Commands		Extract LLM System Prompt	Erode AI Model Integrity
Search Open AI Vulnerability Analysis	LLM Prompt Crafting	Phishing ^{&}		LLM Prompt Injection	Manipulate AI Model		Evade AI Model	RAG Credential Harvesting	Discover AI Model Ontology			Manipulate AI Model		LLM Data Leakage	Erode Dataset Integrity
Search Open Technical Databases ^{&}	Obtain Capabilities ^{&}	Prompt Infiltration via Public-Facing Application		User Execution ^{&}	Modify AI Agent Configuration		Exploitation for Defense Evasion ^{&}	Unsecured Credentials ^{&}	Discover AI Model Outputs			Verify Attack		LLM Response Rendering	Evade AI Model
Search Open Websites/Domains ^{&}	Poison Training Data	Valid Accounts ^{&}			Poison Training Data		False RAG Entry Injection		Discover AI Model Hallucinations						External Harms
Search Victim-Owned Websites ^{&}	Publish Hallucinated Entities				Prompt Infiltration via Public-Facing Application		Impersonation ^{&}		Discover LLM System Information						Machine Compromise
	Publish Poisoned AI Agent Tool				RAG Poisoning		LLM Jailbreak		Process Discovery ^{&}						Spamming AI System with Chaff Data
	Publish Poisoned Datasets						LLM Prompt Obfuscation								
	Publish Poisoned Models						LLM Trusted Output Components Manipulation								
	Retrieval Content Crafting						Manipulate User LLM Chat History								
	Stage Capabilities ^{&}						Masquerading ^{&}								
							Modify AI Agent Configuration								



OWASP AI Exchange threat model one-pager owaspai.org/go/threatmodel/

AI-specific?	Lifecycle	Attack surface	Threat	When	Impact
AI	Runtime	Input attack	Direct prompt injection	If the model is GenAI (e.g., a Large Language Model) and not classic machine learning or a heuristic model	Unwanted model behaviour. The impact depends very much on if and how it can actually cause harm: - What (cascading) actions can the model trigger, leading to harm. Execute code? Physical actions? - Can the model trigger actions that retrieve sensitive data, and actions that send it out? - Could output be harmful content or misinformation leading to harm?
			Indirect prompt injection	If the model is GenAI and the system inserts untrusted data into the prompt	
			Evasion	If the model performs a classification and an adversary can influence input.	
		Break into deployed model	Direct runtime model poisoning	This conventional attack is always possible in theory. Protection depends on where the model is deployed	
		Break into augmentation data	Augmentation data manipulation	If the system inserts sensitive data in the model input (e.g. RAG, system prompts, or data from memory)	
	Development	Break into train/finetune data	Direct development-time model poisoning	If you train your own model	- Does untrusted data go in a prompt of a model with elevated privileges?
			Data poisoning		
		Compromise supply chain	Supply-chain model poisoning	If the model is from a supplier	
			Supply chain data poisoning	If the data is from a supplier	
	Runtime	Input attack	Disclosure in output	If the system inserts data in the model input (e.g. RAG, system prompts, or data from memory)	Unauthorized access to augmentation data.
		Break into deployed system	Direct augmentation data leak		
	Runtime	Input attack	Disclosure in output	If you train your own model and training data is sensitive (for membership inference: the fact of being in the set is sensitive).	Unauthorized access to training data.
			Model inversion / Membership inference		
	Development	Break into training data	Direct training data leak		
	Runtime	Input attack	Model exfiltration	If you train your own model and it is intellectual property (e.g. not public) or the model is susceptible to an input attack.	The model is stolen. It may be used by a competitor, or used by an attacker to prepare or perform an input attack on.
		Break into deployed model	Direct runtime model leak		
	Development	Break into model data	Direct development-time model leak		
	Runtime	Input attack	AI resource exhaustion	Always a possibility, depending on if the model or system are sensitive to it.	Model unavailability or fund depletion (if the model runs as a paid service).
	Runtime	All IT	Input data leak	If the input data is sensitive and there is a threat of a conventional attack on it, in transit or at rest.	Unauthorized access to input. Example: the model input may be stored at a cloud AI provider log, and leak from there.
	Runtime	All IT	Output contains conventional injection	If the output is text and is interpreted downstream (web browser, database).	C, I, A of any asset. The injection may succeed in a cross site scripting, sql injection etc.
Conventional	Runtime	All IT	Generic runtime security threats	Require their own conventional threat modeling on the runtime architecture.	C, I, A of any asset.
	Development	All IT	Conventional development-environment and supply-chain threats	Require their own conventional threat modeling on the development environment.	C, I, A of any asset.

<https://owaspai.org/go/threatmodel/>

[OWASP AI Exchange](https://owaspai.org/go/threatmodel/)

TRIANGLE OF FAILURE

Governance • Visibility • Control

GOVERNANCE



Weak Policies
& Standards

RISK & EXPOSURE

VISIBILITY



Unknown Data Assets

CONTROL



Inadequate Access Controls

DATA BREACHES • PRIVACY VIOLATIONS • COMPLIANCE PENALTIES

Most organizations don't have a security problem — they have a data understanding problem.

Governance Gap

- Policies exist but aren't enforced
- No accountability (no data owners)

Visibility Gap

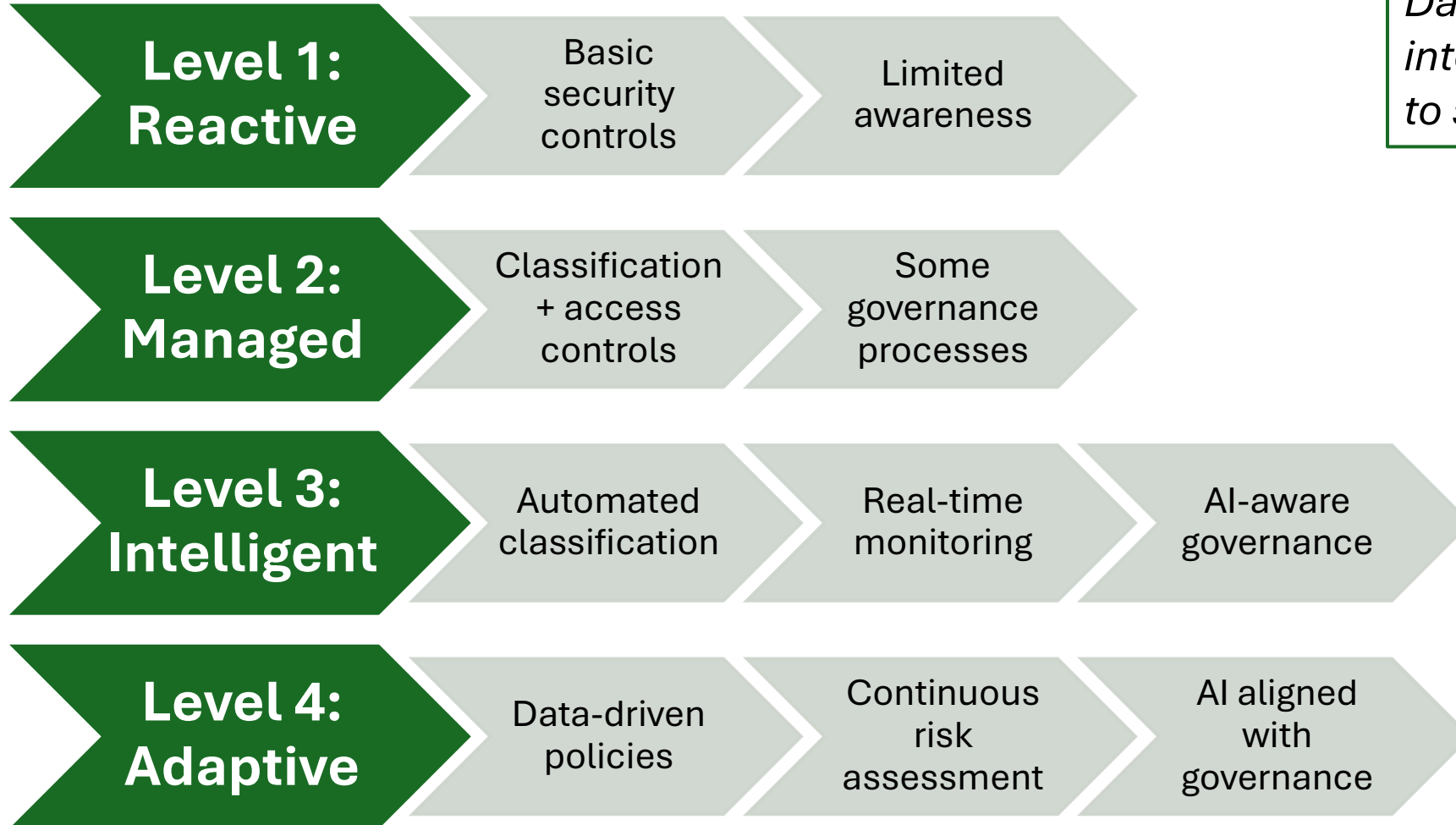
- Unknown data locations
- No lineage tracking

Control Gap

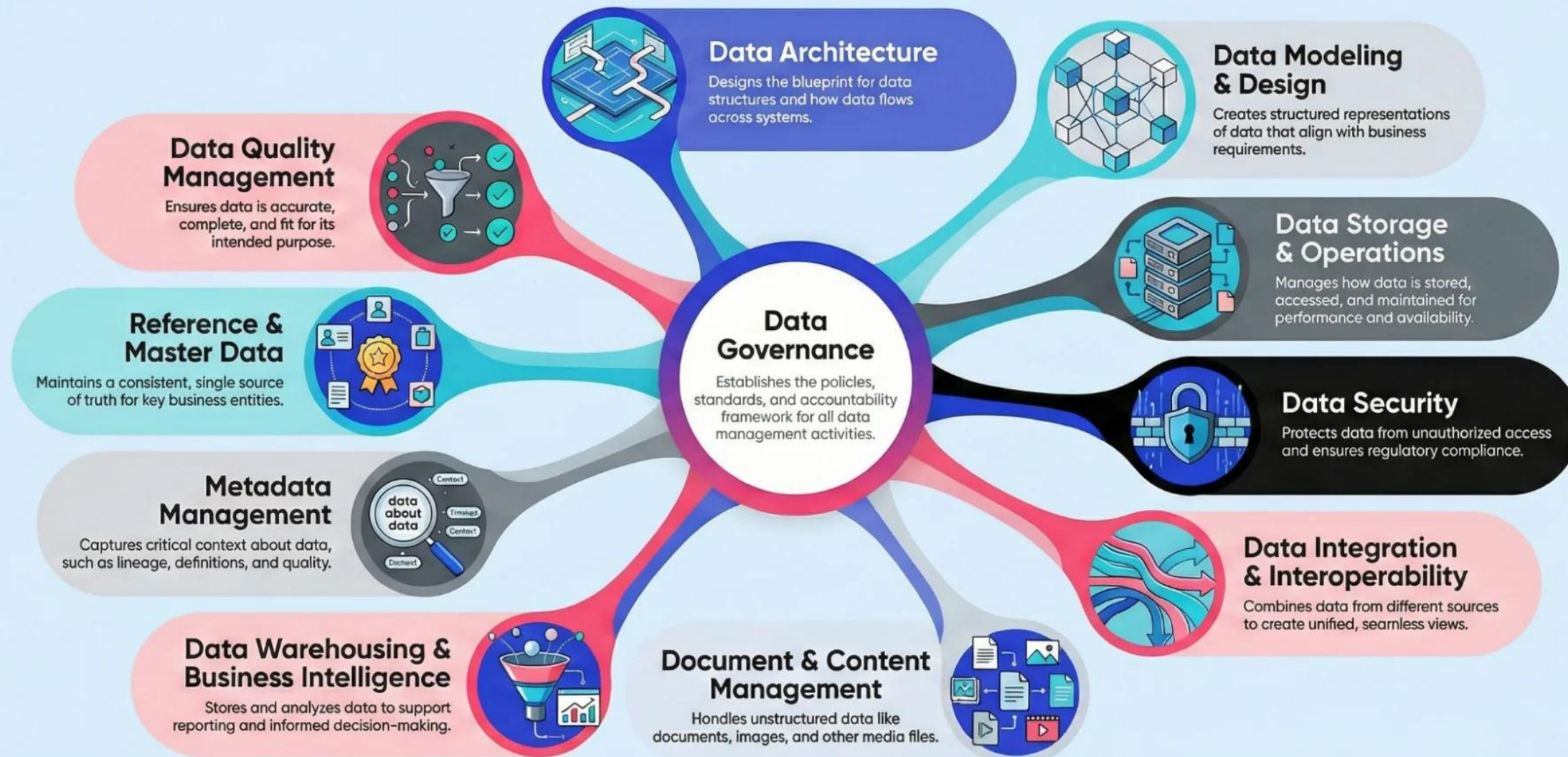
- Access not tied to sensitivity
- No monitoring of data usage

The Shift: From Data Protection to Data Intelligence

Data protection must evolve into data intelligence to support AI safely.



The DAMA Wheel of Data Management



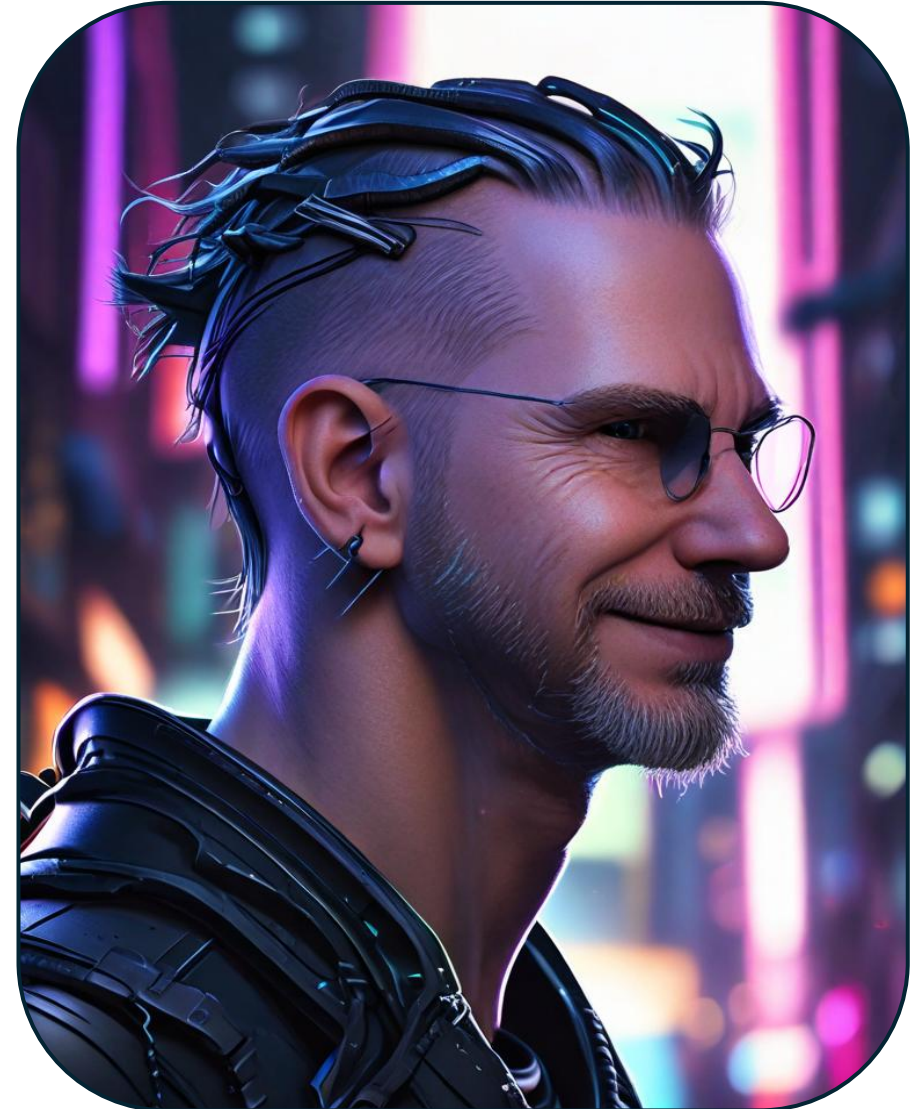
Source: <https://atlan.com/dama-dmbok-framework/>

ISACA Omaha – April 2026

Data, AI, & Zero Trust

TL;DR: AI Lies

**Trust
&
Verify**



Zero Trust Forrester

***Data Security
is at the heart of
Zero Trust.***

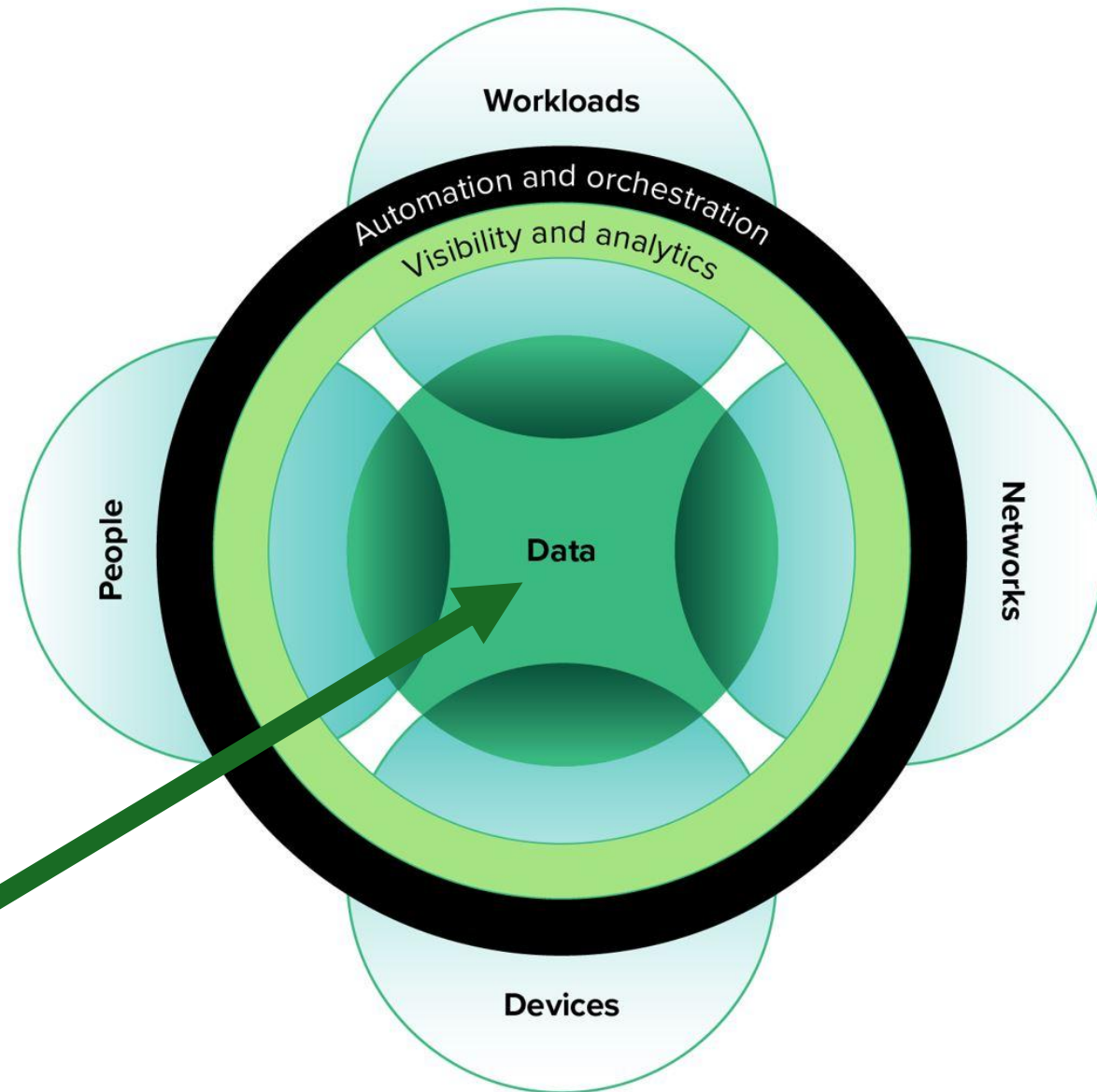


Image source: [Zero Trust Security: The Business Benefits And Advantages \(forrester.com\)](https://www.forrester.com/resources/article/zero-trust-security-the-business-benefits-and-advantages/)

Federal Zero Trust Data Security Guide

https://resources.data.gov/assets/documents/Zero-Trust-DataSecurityGuide_RevisedMay2025_CIO.govVersion.pdf

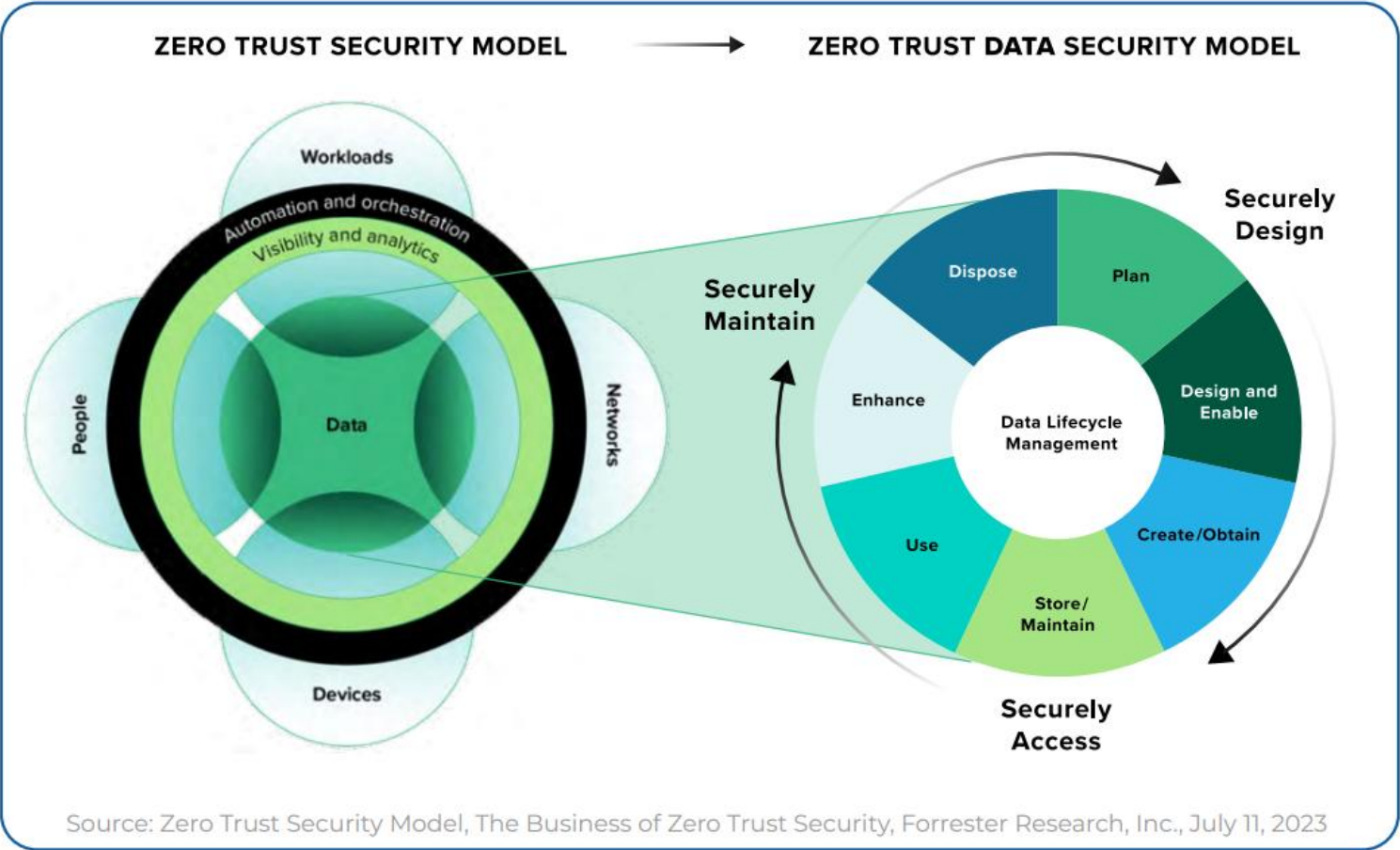


Figure 2, page 8

Zero Trust Data Security Principles

Principle	Why?
Adopt a data-centric view	Data is everywhere and exists in different formats with varying levels of sensitivity and value. Protecting critical data requires visibility, analytics, and automation across the entire digital ecosystem.
Implement standardized least privilege and strictly enforce access control	The bedrock principles of ZT are that all entities are untrusted, least privilege access is enforced, and comprehensive security monitoring is implemented.
Promote data resiliency and integrity	The value of data is maximized when it is available, accessible, and trustworthy. The Federal government relies on quality data to conduct business and deliver services to the public.
Integrate data and security literacy	Data and security practitioners must understand each other's nomenclature to effectively safeguard their agencies' data and enable appropriate use.
The impact of data security must be measurable and actionable	Meaningful analytics that produce actionable insights can help to prevent breaches and reduce the impact of breaches when they do occur.
Data security is risk-informed throughout the data lifecycle	Each stage of the data lifecycle has specific security requirements. Security controls must address risks to the data, from the data, and in the data.
Balance priorities — make the most with what you have	ZT principles will shape existing practices, processes, and perimeters. As practitioners understand these changes, they can assess whether their current cyber infrastructure meets these evolved needs.

Table 1, page 9

Four Foundational Pillars Areas

Data policies and procedures:

Define standards
for acquisition,
access, quality,
and retention

Data catalogs and lineage:

Enable visibility
and
understanding
of data flows

Data privacy and security:

Apply controls for
protection,
access
governance,
and
compliance

Data collaboration:

Foster cross-
functional data
sharing with
appropriate
guardrails

A Practical Playbook

Step 1: Identify Critical Data

- “What data would hurt us most if exposed or misused?”

Step 2: Assign Ownership

- Every critical dataset has a business owner

Step 3: Classify + Tag

- Sensitivity levels (public, internal, confidential, regulated)

Step 4: Align Access to Sensitivity

- Least privilege + role-based access

Step 5: Monitor Usage

- Who is accessing what, when, and why?

Step 6: Apply AI Guardrails

- Control training data
- Restrict sensitive inputs
- Audit outputs

Double Down on Data Hygiene

Data quality is foundational for both governance and security, especially with AI adoption:

Understand what data you have and define what requires protection

Form cross-functional working groups to align on data access governance

Establish processes for cleaning redundant, obsolete, and trivial data

Implement data security posture management (DSPM) capabilities

References:

- <https://www.forrester.com/blogs/thinking-about-dam-in-2026-start-here/>
- <https://www.youtube.com/watch?v=CL0fqocBx1Q>

AI ISN'T YOUR BIGGEST RISK— YOUR DATA PRACTICES ARE.

AI JUST MAKES THEM VISIBLE FASTER.



Next Steps

*AI doesn't create new risks—
it exposes the ones already hiding in your data.*

- **Identify and prioritize critical data assets** — determine which datasets would cause the most harm if exposed or misused.
- **Assign clear ownership and accountability** — ensure every critical dataset has a designated business owner responsible for its governance.
- **Implement classification and tagging** — label data by sensitivity (public, internal, confidential, regulated) to guide protection and access.
- **Align access controls with sensitivity** — apply least-privilege principles and monitor usage to detect anomalies and misuse.
- **Establish a governance council and maturity roadmap** — drive accountability, measure progress with KPIs, and evolve toward AI-aware governance.

KEY TAKEAWAYS:



Poor Data Practices Create Big Risks



Visibility & Control Are Essential



AI Amplifies Existing Weaknesses

AI exposes the gaps you can't see.



Questions & Discussion

References – Where you can learn more

- ISACA Whitepaper, “[Achieving Data Security and Compliance](#)”
- ISACA Blog, “[Essential Assumptions for Effective Data Security](#)”
- Hyperproof, “[Data Protection Strategies for 2026](#)”
- Atlan, “[DAMA DMBOK Framework: An Ultimate Guide for 2026](#)”
- [Federal Zero Trust Data Security Guide](#)



THE DEVIL IS IN THE DATA

Why AI Exposes Your Weakest Controls

DATA SECURITY • PRIVACY RISKS • COMPLIANCE CHALLENGES

“AI doesn’t introduce new data risks — it amplifies the ones you’ve been tolerating.”

Ron Woerner, CISM

President, Chief Curmudgeon, Cyber-AAA, LLC,
<https://www.linkedin.com/in/ronwoerner/>

